



Cybersecurity

Module 2 Challenge Submission File

Assessing Security Culture

Make a copy of this document to work in, and then answer each question below the prompt. Save and submit this completed file as your Challenge deliverable.

Step 1: Measure and Set Goals

1. Using outside research, indicate the potential security risks of allowing employees to access work information on their personal devices. Identify at least three potential attacks that can be carried out.

Three potential attacks from allowing employees to access work information on their personal devices are “data leakage”, “device infection”, and “malicious apps”.

<https://www.cimcor.com/blog/7-scariest-byod-security-risks-how-to-mitigate>

2. Based on the previous scenario, what is the preferred employee behavior? (For example, if employees were downloading suspicious email attachments, the preferred behavior would be that employees only download attachments from trusted sources.)

Based on previous scenarios the preferred behavior for data leakage is by using app segregation so that personal and business data is separated. Preferred behavior for device infection is making sure your phone’s OS is always updated and on the current version. And lastly the preferred behavior for malicious apps is being trained on how to spot a malicious app and not downloading bloatware/malware type apps.

<https://www.cimcor.com/blog/7-scariest-byod-security-risks-how-to-mitigate>

3. What methods would you use to measure how often employees are currently *not* behaving according to the preferred behavior? (For example, conduct a survey to see how often people download email attachments from unknown senders.)

A simple method to measure these behaviors would be a simple mandatory survey by HR. The survey would ask what version your phone's OS system is, do you have any 3rd party non official apps, and do you have a VPN for your phone.

4. What is the goal that you would like the organization to reach regarding this behavior? (For example, to have less than 5% of employees downloading suspicious email attachments.)

My goals would be 1% or less of employees having an up to date OS on their phone. 5% or less of employees downloading bloatware apps. And 1% or less of employees having a company VPN associated with their phone.

Step 2: Involve the Right People

5. List at least five employees or departments that should be involved. For each person or department, describe in 2–3 sentences what their role and responsibilities will be.

Five departments that should be involved would be: human resources, management, legal, operations, and the IT department. Human resources is in charge of managing employees at a base level. Then determining whether or not it is an offense that needs addressing or correcting. Management, manages the employees. They serve as the companies' structure and support and help employees understand what their tasks and duties are. The legal department keeps the company and employees compliant with current laws and practices. They would also be responsible for helping teams follow rules and regulations as well. The operations team would help make the employees make smart and tactical decisions that would benefit the company. They would make sure that efficiency is staying in place and not declining. Lastly the IT department would be in charge of all the software and information systems in the company. They would also be in charge of managing and maintaining hardware.

<https://www.linkedin.com/pulse/day-45-understanding-role-legal-department-wicky-david/>

Step 3: Training Plan

6. How frequently will you run training? What format will it take (e.g., in-person, online, a combination of both)?

Training would be run quarterly, so 4 times a year, and it would be done through a HR training portal.

7. What topics will you cover in your training, and why? (This should be the bulk of the deliverable.)

The main topics that it would cover will be data leaks and how to prevent them, how to prevent your device from getting infected, and app safety and third party downloads.

8. After you've run your training, how will you measure its effectiveness?

We would measure effectiveness by conducting an employee survey at the beginning of the year and the end of the year and comparing the two surveys to see if results improved. As well as having IT pull data and see how many devices and employees were still having issues with the aforementioned security risks.

Bonus: Other Solutions

9. List at least two other potential solutions. For each one, indicate the following:
 - a. What type of control is it? Administrative, technical, or physical?
 - b. What goal does this control have? Is it preventive, deterrent, detective, corrective, or compensating?
 - c. What is one advantage of each solution?
 - d. What is one disadvantage of each solution?

Another potential solution would be a phone VPN. This would be a technical control. It is a preventive measure to help make sure an event does not occur. One advantage of a VPN would be that your internet traffic is protected against outside traffic. The only disadvantage would possibly be slow connection speeds, as VPNs tend to eat up a certain amount of bandwidth and internet speed.

<https://www.cisco.com/c/en/us/products/security/vpn-endpoint-security-clients/what-is-vpn.html>

Another solution would be to have a new policy to not allow employees to access work information on their personal devices. This would be an administrative control. The goal that this control would have would be a deterrent control. An advantage would be that all employees would not be able to access work information on their personal devices, bringing the risk factor of this happening down close to 0% of employees being at risk. The disadvantage of this would be less productivity. Employees would be forced to only access and work on work information in the office and not be able to work from home or check on things from home.